
LAB 02 REPORT

Passive Reconnaissance on example.com

OSINT and DNS Enumeration Report

Course: Intrusion Testing & Penetration Testing

Lab: Day 06 — Lab 02: Passive Reconnaissance on a Controlled Mock Domain

Student: Mohammad Salem Hassani

Instructor: Asen Grozdanov

Institution: Dawson College

Date: March 15, 2026

Executive Summary

This laboratory exercise focused on the reconnaissance phase of penetration testing — specifically the collection of open-source intelligence (OSINT) about target domains using exclusively passive techniques. The primary target analyzed was example.com, a well-known documentation domain operated by IANA and fronted by Cloudflare infrastructure. A secondary mock domain, acmecorplab.xyz, was examined to demonstrate OSINT behaviour on low-profile targets.

Key findings include confirmation that both domains are fronted by Cloudflare CDN, which obscures origin server details and provides DDoS mitigation. DNS records reveal managed nameservers, a restrictive SPF policy (v=spf1 -all), and dual geographically distributed A record IPs. Shodan analysis confirmed that direct IP access is blocked at the network edge, forcing all traffic through Cloudflare's edge network.

Tools deployed: WHOIS, dig, theHarvester, OWASP Amass, Shodan, and Maltego CE. From a security perspective, Cloudflare provides a strong defensive posture by concealing origin infrastructure; however, subdomain enumeration and certificate transparency logs could still reveal internal naming conventions in real-world engagements.

Section 1 — Introduction & Lab Objectives

1.1 What is Passive Reconnaissance?

Passive reconnaissance, also known as Open-Source Intelligence (OSINT), is the practice of gathering information about a target using only publicly available data sources — without directly interacting with the target's infrastructure. This phase corresponds to Phase 1 of the Penetration Testing Execution Standard (PTES) and is critical for mapping the attack surface before any active exploitation begins.

Unlike active reconnaissance (e.g., Nmap port scans), passive techniques leave no trace in target system logs, making them the preferred starting point in professional engagements.

1.2 Learning Objectives

By completing this lab, the following competencies were demonstrated:

- Understanding the strategic role of passive reconnaissance in the PTES methodology
- Performing WHOIS lookups to extract domain registration and registrar data
- Using dig and nslookup to enumerate DNS records: A, MX, NS, TXT, SOA, and PTR
- Deploying theHarvester to aggregate email addresses and subdomains from OSINT engines
- Running OWASP Amass in passive mode for subdomain enumeration via DNS and certificate transparency
- Querying Shodan to discover exposed services, open ports, and infrastructure fingerprints
- Building visual intelligence graphs in Maltego CE to map entity relationships
- Producing professional OSINT findings documentation suitable for client delivery

1.3 Legal and Ethical Disclaimer

Authorization Statement

All reconnaissance activities were performed exclusively against authorized targets: the public documentation domain example.com and the instructor-provided mock domain acmecorplab.xyz. No unauthorized scanning or data collection was performed against live production systems. All techniques comply with Canadian cybersecurity law (Criminal Code Section 342.1) and the Computer Fraud and Abuse Act (CFAA).

Section 2 — Lab Environment Setup

2.1 System Configuration

Component	Details
Operating System	Kali Linux 2024.x (rolling release)
Kernel	Linux 6.x
Working Directory	~/labs/day06-lab02/
Primary Target	example.com
Secondary Target	acmecorplab.xyz
Network	Isolated lab environment

Table 1: Lab environment configuration

2.2 Directory Structure

A structured directory hierarchy was created to organize evidence and tool outputs systematically:

```
mkdir -p ~/labs/day06-lab02/{whois,dns,harvester,amass,shodan,maltego,report,screenshots}
cd ~/labs/day06-lab02
```

Figure 1: Lab directory structure — organized subdirectories for each tool's output

The directory structure separates outputs by tool category, enabling systematic documentation and traceable evidence chains for the final report.

2.3 Target Variable Configuration

The target domain was stored as an environment variable for consistent reuse across all commands:

```
export TARGET="example.com"
echo $TARGET
```

Figure 2: Setting the \$TARGET environment variable to example.com

2.4 Tool Installation and Verification

Tool	Installation Method	Purpose
WHOIS	Pre-installed (whois --version)	Domain registration lookups
dig / nslookup	Pre-installed (dnsutils package)	DNS record enumeration
theHarvester	sudo apt-get install theharvester -y	Email/subdomain OSINT
OWASP Amass	sudo apt-get install amass -y	Passive subdomain enumeration
Shodan CLI	pip3 install shodan	Internet-exposed service query
Maltego CE	sudo apt-get install maltego -y	Visual entity relationship mapping
jq	sudo apt-get install jq -y	JSON output parsing

Table 2: Tools installed and verified for this lab

Section 3 — WHOIS Enumeration

3.1 Domain WHOIS Lookup

WHOIS is a query-and-response protocol standardized in RFC 3912, used to retrieve domain registration records. It is the first reconnaissance step in any passive OSINT engagement.

```
whois $TARGET | tee whois/whois_basic.txt
```

Figure 3: Complete WHOIS output for EXAMPLE.COM

3.2 WHOIS Analysis — Domain Record

WHOIS Field	Value Found	Intelligence Value
Domain Name	EXAMPLE.COM	Primary target identifier
Registry Domain ID	2336799_DOMAIN_COM-VRSN	Verisign registry reference
Registrar	RESERVED-Internet Assigned Numbers Authority	IANA-reserved documentation domain
Creation Date	1992-01-01	34+ year domain — extremely stable
Updated Date	2024-08-14	Recently maintained and active
Expiry Date	2026-08-13	Valid registration confirmed
Name Servers	ELLIOTT.NS.CLOUDFLARE.COM, HERA.NS.CLOUDFLARE.COM	DNS delegated to Cloudflare
Domain Status	clientDeleteProhibited, clientTransferProhibited, clientUpdateProhibited	Registry-locked; protected from hijacking
DNSSEC	signedDelegation	Cryptographic DNS integrity enabled

Table 3: WHOIS field analysis for example.com

Critical Analysis

- **Domain Age (1992):** One of the oldest registered domains on the internet. Its 34-year history, combined with IANA ownership, confirms legitimacy as a documentation resource as defined by RFC 2606.
- **Registry Locks:** The three clientProhibited status codes prevent unauthorized modification, transfer, or deletion — appropriate hardening for a critical infrastructure domain.

- **Cloudflare Delegation:** Nameservers delegated to Cloudflare mean the registrant does not self-host DNS infrastructure, gaining DDoS resilience and geographic distribution.
- **DNSSEC signedDelegation:** Cryptographic signing of DNS responses protects against DNS spoofing and cache poisoning attacks.

3.3 IP Address WHOIS Lookup

After resolving the domain's IP via dig (covered in Section 4), WHOIS was queried against the resolved IP to identify the hosting organization:

```
TARGET_IP=$(dig +short A $TARGET | head -1)
echo $TARGET_IP    # → 104.18.26.120
whois $TARGET_IP | tee whois/whois_ip.txt
```

Figure 4: WHOIS lookup for IP 104.18.26.120 confirming Cloudflare ownership

3.4 IP WHOIS Analysis

Field	Value
NetRange	104.16.0.0 – 104.31.255.255
CIDR	104.16.0.0/12
NetName	CLOUDFLARENET
Organization	Cloudflare, Inc. (CLOUD14)
Address	101 Townsend Street, San Francisco, CA 94107, US
RegDate	2010-07-09
Updated	2024-11-25
Abuse Contact	abuse@cloudflare.com

Table 4: IP WHOIS data for 104.18.26.120 — ARIN registry

Security Implications

- The origin web server's real IP address is hidden from public view — all exposed IPs belong to Cloudflare's edge network.
- Direct attacks against the origin infrastructure require first bypassing Cloudflare's proxy layer, which is non-trivial.
- Geolocation and organizational attribution data reflect Cloudflare (San Francisco), not the actual domain owner or hosting region.

- DDoS attacks against the domain are absorbed by Cloudflare's anycast network rather than reaching the origin.

Section 4 — DNS Reconnaissance with dig

DNS records provide critical intelligence about a domain's infrastructure — including mail servers, authoritative nameservers, IP addresses, and authentication policies. The dig utility was used to systematically enumerate all relevant record types.

4.1 A Records — IPv4 Addresses

A records map a domain name to its IPv4 address(es):

```
dig A $TARGET | tee dns/a_record.txt
```

Figure 5: dig A record lookup — dual IPv4 addresses returned

Two IPv4 addresses were returned:

- 104.18.26.120 — Cloudflare edge node
- 104.18.27.120 — Cloudflare edge node (load balancing peer)

Both belong to Cloudflare's IP range (104.16.0.0/12). The dual A records indicate active load balancing and redundancy — DNS-based traffic distribution across multiple edge nodes improves availability and absorbs peak load without single-point failure.

Query metadata:

- Query time: 20 ms — fast response indicating a nearby DNS resolver
- Server: 192.168.0.1#53 — local network resolver in use
- MSG SIZE: 72 bytes — compact response with minimal overhead

4.2 MX Records — Mail Exchange

MX records define which mail servers handle inbound email for the domain:

```
dig MX $TARGET | tee dns/mx_record.txt
```

Figure 6: dig MX record — Null MX configuration confirmed

Result: example.com. 300 IN MX 0 .

A priority value of 0 combined with a single dot (.) as the exchange constitutes a Null MX record (RFC 7505). This explicitly signals that no mail server exists for this domain and instructs all sending MTAs to reject delivery attempts outright.

Security Implication

The Null MX record prevents email spoofing using @example.com addresses — no mail transfer agent will accept or relay messages claiming to originate from this domain. This is appropriate and correctly configured for a documentation domain.

4.3 NS Records — Authoritative Name Servers

```
dig NS $TARGET | tee dns/ns_record.txt
```

Figure 7: dig NS record — Cloudflare authoritative nameservers with glue records

Authoritative nameservers returned:

- elliott.ns.cloudflare.com
- hera.ns.cloudflare.com

The ADDITIONAL SECTION provides glue records resolving the nameserver hostnames:

Nameserver	IPv4 (A)	IPv6 (AAAA)
elliott.ns.cloudflare.com	172.64.35.228, 108.162.195.228	2606:98c1:50::ac40:23e4 2606:4700:58::a29f:2ce4
hera.ns.cloudflare.com	172.64.32.162, 108.162.192.162	2803:f800:50::6ca2:c3e4 2606:4700:50::adf5:3aa2

Table 5: Cloudflare nameserver IP addresses (glue records)

- Full dual-stack (IPv4 + IPv6) support ensures accessibility from modern networks.
- Geographically distributed Cloudflare anycast nameservers provide DDoS resilience for DNS queries themselves.

4.4 TXT Records — SPF and Verification Tokens

```
dig TXT $TARGET | tee dns/txt_record.txt
```

Figure 8: dig TXT record — SPF policy and ownership verification token

Two TXT records were discovered:

Record 1	v=spf1 -all
Record 2	_k2niy4vw3qtb4skdx9e7dxt97qrmmq9 (domain ownership verification token)

SPF Policy Analysis

The record `v=spf1 -all` is the most restrictive SPF configuration possible. The `-all` qualifier instructs receiving mail servers to issue a HARD FAIL for any message claiming to originate from `@example.com` — regardless of source IP. No mail servers whatsoever are authorized for this domain.

DMARC and DKIM

No DMARC record was found at `_dmarc.example.com`, and no DKIM selector records were detected. Given the hard-fail SPF policy, additional email authentication mechanisms are unnecessary — the domain already rejects all mail at the SPF evaluation stage. For a production domain, DMARC with `p=reject` would be recommended for reporting visibility.

Verification Token

The second TXT record is a domain ownership verification token — a randomly generated string used by a third-party service (e.g., Google Workspace, Azure AD, or a certificate authority) to confirm that the party requesting verification controls the domain's DNS zone.

4.5 Reverse DNS Lookup — PTR Records

```
dig -x $TARGET_IP | tee dns/reverse_dns.txt
```

Figure 9: Reverse DNS lookup for 104.18.26.120 — Cloudflare PTR record

The PTR query for 104.18.26.120 returns a record within Cloudflare's `in-addr.arpa` delegation zone. The SOA record points to `cruz.ns.cloudflare.com`, confirming Cloudflare manages reverse DNS for this IP range. No application-specific hostname is exposed — typical for CDN edge IPs that serve thousands of customer domains simultaneously, by design preventing information leakage.

4.6 Cross-Resolver Validation

To detect potential DNS hijacking or cache poisoning, the domain was queried via Google's public resolver:

```
dig NS $TARGET @8.8.8.8
```

Figure 10: NS query via Google DNS (8.8.8.8) for cross-validation

Results from the Google DNS resolver were identical to those from the local resolver, confirming consistent DNS propagation globally and the absence of DNS tampering or split-horizon manipulation.

4.7 Connectivity Verification

```
ping -c 4 $TARGET
```

Figure 11: Ping test confirming connectivity to Cloudflare edge node

Results: 4 packets transmitted, 4 received, 0% packet loss. RTT min/avg/max = 22.221 / 34.482 / 40.939 ms. Low latency and zero packet loss confirm the Cloudflare edge is fully reachable and responding normally.

Section 5 — Subdomain Discovery

Subdomain enumeration is a critical OSINT technique that reveals additional attack surface areas — development servers, staging environments, exposed admin panels, and internal service endpoints that may not be intended for public access.

5.1 theHarvester

theHarvester aggregates data from multiple search engines, certificate transparency logs, and public OSINT databases to discover email addresses, subdomains, and associated IP addresses. Version 4.10.1 (Christian Martorella / Edge-Security Research) was used.

```
theHarvester -d acmecorplab.xyz -b duckduckgo -l 100 -f harvester/output.html
```

Figure 12: theHarvester execution against acmecorplab.xyz

Results returned:

- IPs discovered: 0
- Email addresses: 0
- Persons identified: 0
- Hostnames/subdomains: 0

Analysis

The absence of OSINT data for acmecorplab.xyz is expected behaviour for a newly registered or deliberately low-profile mock domain. This outcome highlights a key principle: OSINT effectiveness is proportional to the target's digital footprint. Domains with no indexed web content, no social media presence, and no third-party integrations yield sparse reconnaissance results — which can itself be a finding of interest in a real engagement.

5.2 OWASP Amass — Passive Subdomain Enumeration

OWASP Amass performs comprehensive passive subdomain enumeration using DNS data sources, certificate transparency logs (CT logs), web archives, and OSINT APIs.

```
amass enum -passive -d $TARGET -o amass/amass_subs.txt
```

Figure 13: OWASP Amass passive enumeration — data source verification phase

During execution, the following informational messages were observed:

- Checking for new libpostal data file — Libpostal data file up to date
- Error loading transliteration module, dir=(null) — Known cosmetic issue; does not affect core enumeration functionality

Amass completed its passive scan and saved discovered subdomains to the output file. For example.com, passive sources yield limited results due to the domain's intentionally minimal presence. In real-world engagements, Amass excels at surfacing forgotten development subdomains through CT log analysis (e.g., dev.target.com, staging-api.target.com).

Section 6 — Shodan Intelligence Gathering

Shodan is a search engine for internet-connected devices. It continuously crawls the IPv4 address space, indexing service banners, SSL/TLS certificates, open ports, and vulnerability identifiers — providing passive intelligence without interacting directly with the target.

6.1 Shodan API Configuration

```
shodan init <API_KEY>
```

Figure 14: Shodan CLI initialization — API key configured successfully

6.2 Host Information Query

```
shodan host 104.18.26.120
```

Figure 15: Shodan host query for 104.18.26.120 — Cloudflare infrastructure details

6.3 Shodan Analysis

Attribute	Value
IP Address	104.18.26.120
City	San Francisco
Country	United States
Organization	Cloudflare, Inc.
Last Indexed	2026-03-15T16:27:09.225416 UTC
Open Ports Detected	10

Table 6: Shodan host summary for 104.18.26.120

Open Ports and Service Banners

Port	Service	Banner / HTTP Title
80/tcp	HTTP	Direct IP access not allowed Cloudflare
443/tcp	HTTPS	400 The plain HTTP request was sent to HTTPS port
2053/tcp	HTTP	400 The plain HTTP request was sent to HTTPS port
2082/tcp	HTTP	Direct IP access not allowed Cloudflare

Port	Service	Banner / HTTP Title
2083/tcp	HTTPS	400 The plain HTTP request was sent to HTTPS port
2086/tcp	HTTP	Direct IP access not allowed Cloudflare
2087/tcp	HTTPS	400 The plain HTTP request was sent to HTTPS port
8080/tcp	HTTP	Direct IP access not allowed Cloudflare
8443/tcp	HTTPS	400 The plain HTTP request was sent to HTTPS port
8880/tcp	HTTP	Additional Cloudflare edge port

Table 7: Shodan open ports and service banners

Security Analysis

1. Direct IP Access Blocked — The banner "Direct IP access not allowed | Cloudflare" confirms that Cloudflare enforces Host header validation. Any HTTP request that does not include a Host header matching an authorized customer domain is rejected, preventing attackers from bypassing DNS to reach the origin server directly.
2. Protocol Mismatch Errors — HTTPS ports returning "400 The plain HTTP request was sent to HTTPS port" is expected behaviour when Shodan's HTTP crawler attempts cleartext connections without TLS. This confirms proper HTTPS enforcement.
3. Multiple Port Support — Ports 2053, 2083, 2087, and 8443 represent Cloudflare's alternative HTTPS ports, used for WebSocket connections, firewall bypass in restricted environments, and customer-specific configurations.
4. No Origin Leakage — Shodan revealed no information about the actual origin web server behind Cloudflare's proxy. Origin cloaking is functioning correctly.

Red Flag Assessment

Indicator	Status	Notes
Default credentials exposed	Not detected	No admin panel accessible
Outdated software with known CVEs	Not detected	Cloudflare manages patching
Admin panels exposed	Blocked	Cloudflare enforces Host header check
Development servers exposed	Not detected	No evidence of staging endpoints
Self-signed SSL certificates	Not detected	Cloudflare provides valid TLS
Unencrypted HTTP on port 80	Mitigated	Port 80 redirects to HTTPS

Table 8: Shodan red flag assessment

Section 7 — Visual Analysis with Maltego CE

Maltego is a visual intelligence and link analysis platform used to map relationships between entities: domains, IP addresses, email addresses, people, organizations, and infrastructure components. The Community Edition (CE) was used for this exercise.

7.1 Transforms Applied

The graph was constructed from a single seed entity (example.com) using the following Maltego transforms:

5. DNS from Domain → To DNS Name — Discovered www.example.com and candidate subdomains
6. DNS from Domain → To MX Record — Identified Null MX mail configuration
7. DNS from Domain → To NS Record — Mapped authoritative Cloudflare nameservers
8. To IP Address [DNS] — Resolved domain to 104.18.26.120 and 104.18.27.120
9. From IP → To Autonomous System — Identified Cloudflare AS as the routing authority
10. From IP → To Location — Geolocated edge nodes to San Francisco, CA

Figure 16: Maltego entity graph — relationships between example.com, DNS records, IPs, and associated entities

7.2 Graph Analysis

The resulting graph illustrates the consolidated intelligence picture:

- All web traffic routes exclusively through Cloudflare's proxy infrastructure — no direct paths to origin exist.
- DNS management is fully delegated to Cloudflare nameservers; the registrant has no self-hosted DNS exposure.
- Email services follow the Null MX configuration — no mail entity exists in the graph.
- The domain's digital footprint is intentionally minimal, consistent with its documentation-only purpose.

In a real penetration test, such a graph serves multiple purposes: identifying third-party service dependencies that may have weaker security postures, finding relationships between employees and infrastructure, and visually presenting attack surface scope to clients in a non-technical format.

Section 8 — Findings Summary and Risk Assessment

8.1 Target Profile

Attribute	Value	Source	Risk Level
Primary Domain	example.com	WHOIS	Informational
IP Addresses	104.18.26.120, 104.18.27.120	DNS A record	Low
Hosting Provider	Cloudflare, Inc.	IP WHOIS	Low
Mail Provider	None (Null MX)	DNS MX record	Low
DNS Provider	Cloudflare	NS record	Low
Subdomains Discovered	0–2	theHarvester / Amass	Informational
Email Addresses Found	0	theHarvester	Informational
SPF Policy	v=spf1 -all (Hard Fail)	DNS TXT	Low
DMARC Policy	Not configured	DNS TXT	Medium
DNSSEC	Enabled (signedDelegation)	WHOIS	Low (Positive)
Shodan Exposed Services	10 ports (Cloudflare edge)	Shodan	Low

Table 9: Consolidated target profile and risk assessment

8.2 Detailed Technical Findings

Finding 1 Cloudflare Infrastructure Protection
Severity: Informational — Positive Security Control All web traffic is routed through Cloudflare's CDN and DDoS protection layer, effectively hiding the origin server IP address. Direct attack paths to the origin are not available via public reconnaissance. Recommendation: Maintain this configuration. Supplement by ensuring origin server firewall rules only accept inbound connections from documented Cloudflare IP ranges, blocking all other sources.
Finding 2 Restrictive SPF Policy (v=spf1 -all)

Severity: Low Risk

The SPF record is configured with a HARD FAIL directive, explicitly rejecting all email claiming to originate from @example.com. No mail servers are authorized for this domain.

Recommendation: Appropriate configuration for a documentation domain. For production domains, add DMARC p=reject to gain visibility into spoofing attempts via aggregate reporting.

Finding 3 Missing DMARC Policy**Severity:** Medium Risk (production domain context)

No DMARC record was detected at _dmarc.example.com. While the hard-fail SPF policy prevents unauthorized sending, the absence of DMARC means no aggregate reporting on spoofing activity is available to the domain operator.

Recommendation: Implement DMARC with p=reject and rua reporting for any production domain. Recommended record: "v=DMARC1; p=reject; rua=mailto:dmarc-reports@[domain]; pct=100"

Finding 4 DNSSEC Implementation**Severity:** Informational — Positive Security Control

DNSSEC is enabled with signedDelegation status, providing cryptographic validation of all DNS responses. This protects users from DNS spoofing and cache poisoning attacks.

Recommendation: Maintain current DNSSEC configuration. Monitor key rollover schedules and validate DS records periodically using dnssec-verify or equivalent tooling.

Finding 5 Minimal OSINT Footprint**Severity:** Informational

Subdomain enumeration via theHarvester and Amass yielded minimal results. No email addresses, employee data, or undocumented subdomains were discovered — consistent with the domain's documentation-only purpose.

Recommendation: For real organizations, this outcome is unusual. Conduct regular self-directed OSINT audits using the same toolset to identify unintended information exposure before adversaries do.

Section 9 — Tool Comparison Matrix

Tool	Data Type Retrieved	Unique Findings	Difficulty (1–5)	Cost
WHOIS	Domain registration, registrar, nameservers, expiry	DNSSEC status, domain age (1992), IANA ownership	1	Free
dig	DNS A, MX, NS, TXT, SOA, PTR records	Dual A records, Null MX, SPF v=spf1 -all, verification token	2	Free
nslookup	Basic DNS queries	Cross-validation of dig results	1	Free
theHarvester	Emails, subdomains, IPs from search engines	Null result for low-profile target — demonstrates footprint importance	2	Free
OWASP Amass	Passive subdomain enumeration via CT logs, DNS	Comprehensive passive sources; best for mature, indexed domains	3	Free
Shodan	Open ports, banners, SSL certs, CVEs	Cloudflare port config, DDoS protection evidence, 10 ports indexed	2	Free tier / Paid
Maltego CE	Visual entity relationships, graph analysis	Visual synthesis of all OSINT data into an actionable intelligence map	4	Free CE / Paid Pro

Table 10: Reconnaissance tool comparison matrix

Tool Selection Guidance

Quick Recon	WHOIS + dig — 5 to 10 minutes. Sufficient for initial domain profiling.
Subdomain Discovery	Amass passive + theHarvester — 30 to 60 minutes. Best coverage across CT logs and OSINT engines.
Infrastructure Intel	Shodan host + search queries — 15 to 20 minutes. Ideal for port mapping and banner analysis.

**Client
Presentation**

Maltego graph export — 45 to 60 minutes. Required for visual attack surface reporting.

Section 10 — Recommendations

10.1 For Domain Operators (General Best Practices)

1. Implement DMARC Policy

Deploy DMARC with enforcement to complement SPF and DKIM:

```
_dmarc.example.com. IN TXT "v=DMARC1; p=reject; rua=mailto:dmarc@example.com; pct=100"
```

2. Enable DNSSEC

If not already enabled, implement DNSSEC to protect DNS integrity and prevent cache poisoning. Ensure DS records are registered with the parent zone (the TLD registry).

3. Maintain CDN / DDoS Protection

Continue routing traffic through Cloudflare or an equivalent reverse proxy. Ensure origin server firewall rules whitelist only documented Cloudflare IP ranges and block all other direct inbound traffic.

4. Audit Subdomain Exposure

Run quarterly subdomain audits using Amass and certificate transparency logs (crt.sh) to identify unauthorized, forgotten, or shadow IT subdomains that may introduce security liabilities.

5. Enable WHOIS Privacy

For production domains containing personal registrant information, enable WHOIS privacy protection to reduce personnel data exposure to OSINT tools.

6. Conduct Regular Self-OSINT

Perform quarterly passive reconnaissance against your own organization's domains using the methodology documented in this report. Identifying information leakage before adversaries do is the most cost-effective risk reduction measure available.

10.2 For Penetration Testers

- Always complete passive reconnaissance before initiating any active scanning to understand the target landscape without triggering IDS/SIEM alerts.

- Use multiple complementary tools — no single OSINT tool has complete coverage of all data sources. Amass + theHarvester + Shodan produce materially richer results than any one tool alone.
- Cross-reference DNS results from at least two independent resolvers (e.g., 8.8.8.8 and 1.1.1.1) to detect DNS hijacking, split-horizon configurations, or cache poisoning anomalies.
- Document all findings with full command output, screenshots, and timestamps. Evidence chains must be reproducible for client deliverables.
- Verify scope boundaries rigorously before any reconnaissance activity. Confirm all targets are explicitly authorized in writing before proceeding.

Section 11 — Conclusion

This laboratory exercise successfully demonstrated the full passive reconnaissance phase of penetration testing against example.com and acmecorplab.xyz using industry-standard OSINT tooling. A systematic methodology was applied: WHOIS for registration intelligence, dig for complete DNS enumeration, theHarvester and Amass for subdomain and email discovery, Shodan for infrastructure fingerprinting, and Maltego for visual relationship mapping.

Key accomplishments:

- Extracted complete domain registration data identifying IANA as operator and Cloudflare as DNS/CDN provider
- Enumerated all DNS record types (A, MX, NS, TXT, SOA, PTR) and analysed their security implications
- Confirmed Cloudflare CDN protection effectively concealing origin server infrastructure
- Identified the restrictive v=spf1 -all SPF policy preventing domain-based email spoofing
- Validated DNSSEC signedDelegation status providing cryptographic DNS integrity
- Discovered and documented 10 open ports on Cloudflare edge infrastructure via Shodan, with none presenting exploitable vectors
- Demonstrated OSINT limitations on low-profile targets (acmecorplab.xyz yielded no results)
- Produced visual entity relationship graphs in Maltego CE

The findings confirm that example.com maintains a strong security posture appropriate for its role as a documentation domain. Cloudflare provides effective origin concealment, DDoS mitigation, and HTTPS enforcement. The Null MX configuration and hard-fail SPF policy together eliminate the email-based attack vector.

Key Takeaway

Passive reconnaissance is not merely preparation — it is intelligence. The quality of what follows in an engagement depends entirely on the rigour of what was learned here.

The reconnaissance data gathered provides a complete foundation for subsequent penetration testing phases — active scanning, vulnerability assessment, and exploitation planning — if authorized. The methodologies and documentation practices applied in this lab are directly transferable to real-world security assessments and red team engagements.